



2023

EXPERT
OIL PROTECT

勒索软件和勒索行为报告

目录

执行摘要	3
勒索呈上升趋势	5
为什么拥有备份还远远不够	7
常见勒索战术	9
谁正在受到攻击?	14
来自暗网泄密网站的见解	15
受影响最严重的行业	18
受影响最严重的地区	21
勒索威胁团伙的目标是什么?	22
从攻击中可以知道哪些信息：示例勒索软件事件	25
APT 何时使用勒索软件	29
结语：2023 年勒索团伙将如何发展	32
向专家咨询	38
研究方法	39
Unit 42 事件响应方法	40
关于 Palo Alto Networks 和 Unit 42	41



执行摘要

威胁行动者越来越多地使用勒索技术来获得对目标企业的影响力并实现自己的目标。尽管近年来勒索软件备受关注，但现代威胁行动者越来越多地使用额外的勒索技术来胁迫目标付款，或者完全放弃勒索软件而自行实施勒索。

虽然在许多情况下动机是金钱，但 Unit 42 也看到有迹象表明，敲诈勒索可能是为了实现一个团伙的更大目标，有时只是为了资助其他活动，但有时却是为了分散注意力。

反过来，企业需要提高防御能力，才能从容应对威胁行动者用于施压的各种方法。如今的事件响应计划不仅需要考虑技术因素，还需要考虑保护企业的声誉，以及如何保护员工和客户，防止他们成为一些勒索者更加积极攻击的目标。

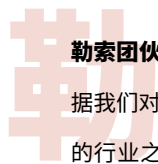
在我们对事件响应案例的回顾以及我们的威胁情报分析师对更大威胁形势的评估中，我们注意到了一些关键点：

多重勒索战术继续增加。

截止到 2022 年年底，在 Unit 42 勒索软件案件中，威胁行动者平均在大约 70% 的案件中参与了数据窃取。与 2021 年年中相比，我们发现平均只有大约 40% 的案件中数据被盗。威胁行动者经常威胁要在暗网泄密网站上泄露被盗数据，这些网站越来越成为他们勒索企业的重要环节。

骚扰是我们在更多勒索软件案件中看到的另一种勒索战术。勒索软件威胁行动者团伙将以企业中的特定个人为目标（通常是高管），进行威胁和不受欢迎的通信。到 2022 年年末为止，骚扰已经出现在约 20% 的勒索软件案件中。与 2021 年年中相比，当时骚扰只出现在 Unit 42 研究的不到 1% 的勒索软件案件中。

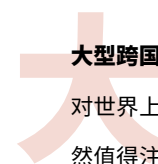




勒索团伙奉行机会主义，但他们攻击的企业有一些共同点。根据我们对暗网泄密网站的分析，制造业是 2022 年受攻击最多的行业之一，有 447 家受攻击企业在泄密网站上公开曝光。

Unit 42 认为，这是由于该行业普遍使用的系统运行在过时的软件上，这些软件不能定期或轻易更新或打补丁，更不用说该行业对停机时间容忍度极低。

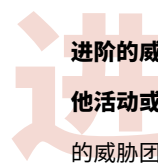
根据泄密网站数据，总部位于美国的企业受到的影响最为严重，占 2022 年观察到的泄密事件的 42%。



大型跨国企业可能成为威胁行动者有利可图的目标。

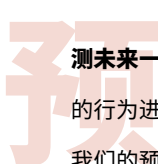
对世界上最大企业的攻击只占公共勒索事件的一小部分，但仍然值得注意。2022 年，福布斯全球 2000 强榜单上的 30 家

企业公开受到勒索企图的影响。自 2019 年以来，这些企业中至少有 96 家的机密文件在某种程度上被公开暴露，这是勒索尝试的一部分。



进阶的威胁团伙可能会通过勒索行为和使用勒索软件来资助其他活动或掩盖这些活动。据观察，来自经济禁运或受制裁国家的威胁团伙使用勒索软件和勒索行为为其行动提供资金。

其他威胁团伙，包括伊朗或中国的一些团伙，在使用勒索软件时似乎有不同的目标。威胁行动者可以从部署勒索软件中获得的不仅仅是金钱，同时还具有破坏和间谍活动的潜力。



测未来一年敲诈勒索的形势。Unit 42 的专家对来年勒索团伙的行为进行了预测。我们的预测包括：

- 2023 年将是大型云勒索软件入侵的一年。
- 与内部人员威胁相关的勒索将会增加。

- 出于政治动机的勒索尝试将会增加。
- 使用勒索软件和勒索行为来分散旨在感染供应链或源代码的攻击。

勒索呈上升趋势

许多威胁犯罪者的首要目标是获得报酬，他们会尽一切努力提高这种情况发生的可能性。因此，我们看到威胁行动者越来越关注勒索技术，通常将这些技术叠加起来使用。

例如，勒索软件攻击者经常使用各种勒索技术（称为多重勒索）来迫使企业做出支付赎金的艰难决定。

Unit 42 观察到勒索软件威胁行动者采用和威胁采用的以下勒索战术：

- **加密：**

企业的数据和文件经过加密，威胁行动者要求支付费用才能恢复对其的访问权限。这一直以来都是勒索软件的主要勒索战术。

- **数据窃取：**

威胁行动者获取企业的数据，并威胁如果不支付费用，就将其传播出去。这往往涉及到暗网泄密网站。威胁行动者越来越多地以可能特别敏感的信息为目标，例如包含个人身份信息 (PII)、客户财务数据、受保护的健康信息 (PHI) 等的文件。

- **分布式拒绝服务 (DDoS)：**

网站和其他资源成为 DDoS 攻击的目标，这种攻击会干扰运营，并吸引企业的注意力。

- **骚扰：**

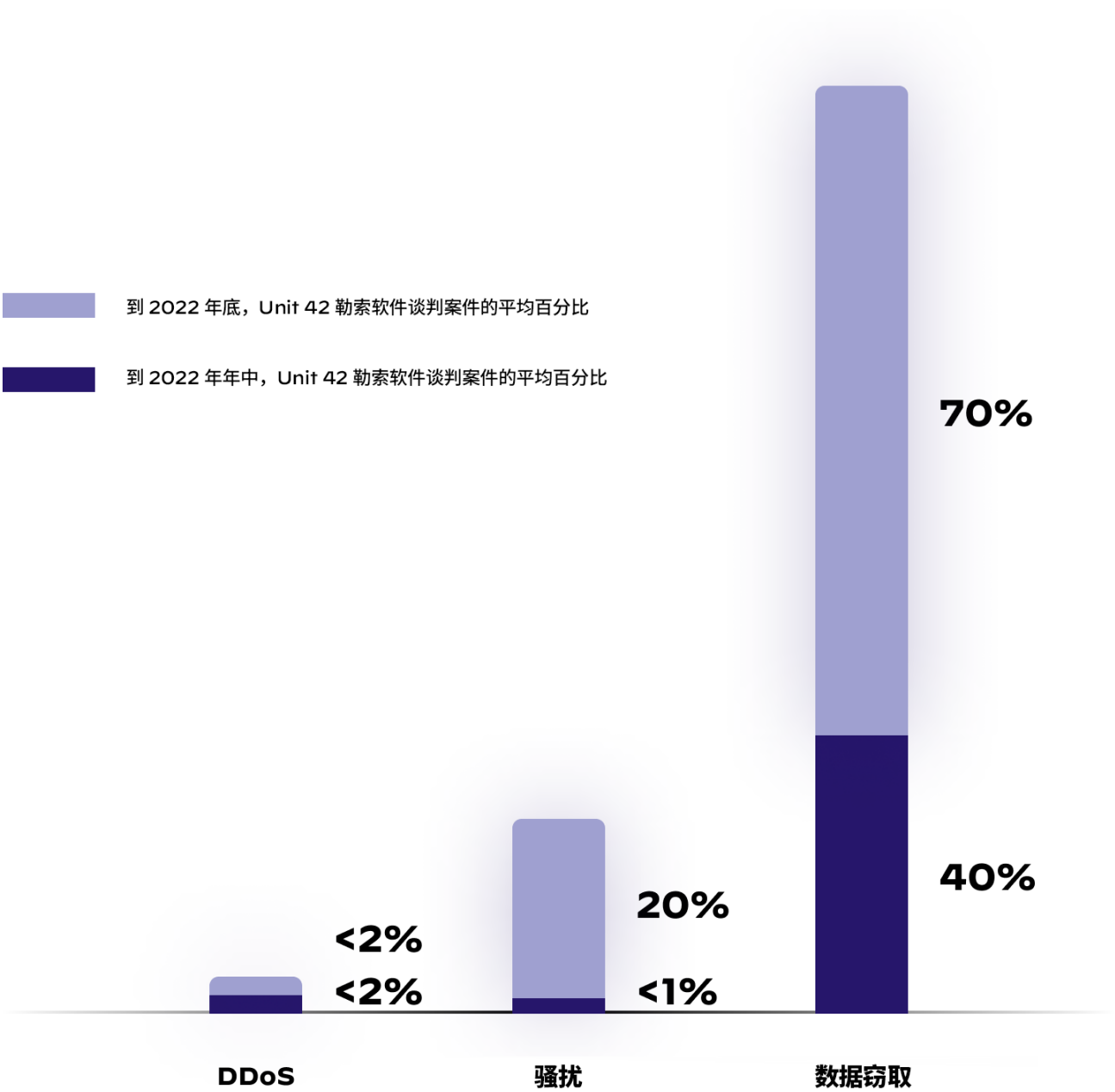
威胁行动者可能会通过电话、电子邮件或其他方式联系企业的员工或客户。他们还可能在社交媒体上发布有关事件的贴文或联系记者。

在一组选定的涉及勒索软件的 Unit 42 事件中，我们发现威胁行动者使用数据窃取和骚扰的方式显著增加。

威胁行动者还可以只使用勒索行为。

在 Unit 42 响应的勒索事件中，有大约 10% 在所涵盖期间不涉及加密。

威胁行动者使用其他勒索战术



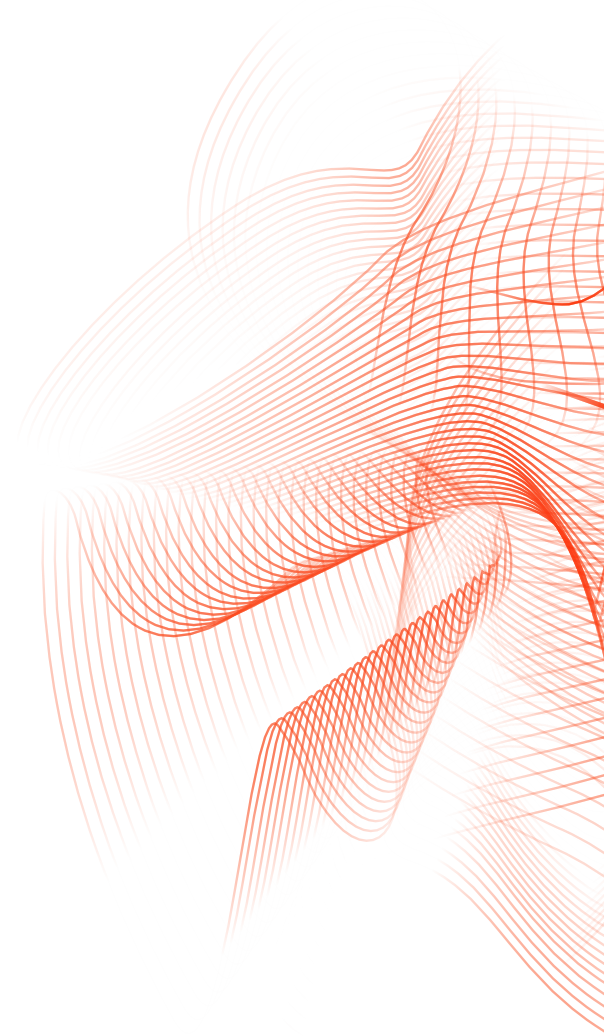
为什么拥有备份还远远不够

随着勒索软件事件最近在新闻和安全团队内部引起关注，许多企业已经掌握了如何防御它们的基本概念。勒索软件攻击者通常会加密文件以使其无法使用，然后要求赎金以换取解密器来恢复加密数据。因此，要提前应对此类攻击，传统的建议是保持备份的最新状态、离线存储并经常测试，这样您的数据就不会受到威胁行动者的摆布。

这仍然是重要的安全保障。不幸的是，当今的许多威胁行动者都采用了更加有效的勒索技术，即使受害者已经备份和保护了自己的数据，威胁行动者仍然可以强迫受害者付款，并且可以最大限度地减少此类攻击造成的运营中断。

通常，威胁泄露敏感数据是迫使企业支付赎金的原因。此类泄密可能导致声誉受损、消费者和合作伙伴失去信心，并可能受到监管机构和当局的罚款和制裁，而备份无法防止上述情况。

我们还看到过这样的事件，企业因为拥有强大的备份而决定不支付赎金，但威胁行为者随后进行了更加激烈的骚扰活动，以至于由此产生的成本超过了索要的赎金。



UNIT 42 执行建议：**为多重勒索准备剧本**

在活跃的勒索事件中，您的事件响应合作伙伴和外部法律顾问的快速支持至关重要。从缓解的角度来看，拥有一个全面的事件响应计划和相应的危机沟通协议将大大减少不确定性。重要的是要知道哪些利益相关者应该参与进来，以及及时做出决定的过程（例如，是否支付，或者谁有权批准支付）。

危机沟通计划还应包括在员工或客户受到骚扰时应该做什么（或避免做什么）。应向企业的员工提供勒索软件骚扰意识培训，为他们配备工具和流程，以便在发生主动骚扰事件时使用。

企业应进行事后损害评估，以验证是否已消除任何残余后门或其他入侵指标 (IoC)（例如计划任务或作业）。这可以确保首次入侵后，威胁行动者无法轻易执行后续攻击。

阅读[使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。

常见勒索战术

加密

加密是勒索软件威胁行动者普遍青睐的一种战术。犯罪团伙经常吹嘘其加密软件的便利性和速度，以此作为招募“同盟”的手段。在首次入侵之后，典型的方法是部署加密文件和传送勒索信的恶意软件。勒索信承诺在付款后交付解密器，提供有关如何联系威胁行动者的说明，并且经常警告不要试图规避攻击。

然而，威胁行为者正在逐渐摆脱仅仅依靠加密进行勒索的方式。在 Unit 42 大多数涉及谈判的勒索软件事件中，还包括至少一种额外的勒索战术。

>> 发生了什么？

您网络上的重要文件已加密，现在它们有“[REDACTED]”扩展名。
要还原文件，您需要按照以下指令操作。

>> 敏感数据

网络上的敏感数据已下载。
如果您不希望敏感数据被发布，最好快速采取行动。

数据包括：

- 员工个人数据，CV、DL、SSN。
 - 完整的网络映射，包括本地和远程服务的凭据。
 - 私人财务信息，包括：公民数据、法院数据、账单、预算、年度报告、银行对账单等
- 您可以在下面链接的个人网页上找到范例。

>> 警告

不要自行修改加密文件。
不要使用第三方软件来恢复您的数据。
您可能会损坏文件，这将导致永久性数据丢失。

>> 我下一步该做什么？

- 1) 从 <https://torproject.org/> 下载并安装 Tor 浏览器
- 2) 导航到：[REDACTED]

图 2. BlackCat 在受感染系统上投放的勒索信示例

数据窃取和多重勒索

在 2021 年年中至 2022 年末期间涉及谈判的勒索软件事件中，大约 53% 的勒索软件团伙威胁要泄露从受害者那里窃取的数据。由于这种战术效果很好，许多威胁行动者将受监管的数据集或高度商业敏感的信息作为目标，以产生最大的影响力。

记者提问

有许多记者询问有关我们和我们的攻击的问题。
如果您是记者，希望询问一些问题，请写下：

1. 您的身份
2. 您来自哪里
3. 要将我们的回答发布在哪里？

我们将尽量在 24 小时内回答所有人的问题。

#常见问题解答：

为什么选择 GTA 作为品牌？
- 关于我们的一些旧文章使用了 GTA 标志，所以我们决定沿用。

你们运作了多长时间？
- 从 2021 年 1 月开始。

是否正在招募同伙，还是已经截止？
- 我们从一开始就单打独斗，没有同盟。

你们是如何组建并成立一个专门的勒索软件团伙的？ ViceSociety 诞生的方式？
- 我们是对渗透测试感兴趣的一群朋友，因此决定尝试一下。

如果法律规定某人不能向你们付款，你会怎么做？ 这很重要吗？ 如果客户没有回应，会发生什么？
- 我们不在乎法律。如果有人不支付赎金或不联系我们，我们会发布其文档。

Vice Society 是否公布了它从“公司名称”获取的所有数据，还是 Vice Society 有其他数据尚未公布？
- 我们一直都公布一切。

能否解释一下公布“公司名称”数据的决定？
- 他们没有付钱。

我们不会回答这类问题：
你们来自哪个国家或地区？
年龄是多大？
使用的 vulns/eve 是什么？

©2021 Copyright Vice Society. 保留所有权利。电子邮件： V.society.official@onionmail.org Vice.Society@onionmail.org

图 3. 来自 Vice Society 泄密网站的“记者提问”页面

这种战术通常被称为多重勒索，通常涉及将有关被入侵企业的信息公开发布到威胁行动者在暗网上维护的网站上。

这些暗网泄密网站有时会威胁在支付赎金的最后期限过后将数据出售给第三方。其他情况下，威胁行动者仅威胁公开发布数据。

泄密网站通常包括某个版本的博客，或者看起来像是客户服务门户的网站，让受影响的企业查看赎金索要状态并与威胁行动者沟通。一些泄密网站甚至设有专门针对记者寻求有关勒索软件团伙信息的版块，网络犯罪分子明显企图强化自身在网络环境中的恶名。

在 2021 年 5 月至 2022 年 10 月的 18 个月时间里，利用数据窃取作为敲诈勒索手段的事件增加了 30 个百分点。Unit 42 预计这种数据窃取和多重勒索的上升趋势将继续下去。

分布式拒绝服务 (DDoS)

虽然 DDoS 仍然是一种勒索战术，但 Unit 42 仅在不到 2% 的勒索软件案件中观察到这种手段。在这些案件中，如果受害者选择忽视而不是就支付赎金进行沟通，威胁行动者会使用 DDoS 来引起企业的注意。虽然我们继续观察到偶尔使用这种战术，但我们认为它在威胁行动者中并没有变得流行，因为它在强制支付方面不如数据窃取和骚扰有效。

骚扰

Unit 42 观察到威胁行动者在我们至少 9% 的涉及谈判的勒索软件事件中利用骚扰作为勒索手段。与 DDoS 一样，威胁行动者在试图引起企业的注意时通常会采用这种勒索战术。然而，与 DDoS 不同的是，威胁行动者似乎更频繁地依靠这种勒索战术。

威胁行动者给公司高管和其他员工打电话并留下语音邮件，向个人发送电子邮件，或者在泄密网站或社交媒体上披露受害者的身份。这些活动的目的是让企业难以回避威胁行动者及其要求。企业不仅要应对勒索软件事件，而且现在还有人事公关问题需要处理。

在 2021 年 5 月到 2022 年 10 月的 18 个月时间里，骚扰作为一种勒索手段，从 Unit 42 每月勒索软件案件中的平均不到 1% 增加到每月平均约 20%。虽然披露的数据和案件信息反映出上升趋势，但这些信息有限且包含明显的异常值。因此，虽然我们认为这种勒索战术将继续被威胁行动者使用，但很难预测它在未来发生的频率。Unit 42 将密切监控这一趋势。

勒索但不加密

大约 10% 的 Unit 42 涉及勒索的事件响应不涉及加密。通常，这些勒索尝试依靠数据窃取。

但是，在少数案例中，威胁行动者将企业的数据彻底删除。这在涉及易受攻击并直接暴露于互联网的数据库时尤为普遍。有几种自动威胁会删除数据库内容，声称这些数据已被泄露，并在新数据库表中留下勒索消息供受害者查找。

在涉及 Karakurt 勒索软件团伙的 Unit 42 案件中，最常见的是将数据窃取作为一种不加密的勒索战术。

我们还调查了几起与 [Luna Moth/Silent Ransom Group](#) 相关的事件。这些威胁行为者以针对多个部门（包括法律和零售）的企业的勒索活动而闻名。活动没有加密，而是依靠社交工程来说服目标提供对系统的远程访问。然后，他们使用访问权限来窃取数据并跟进勒索企图。

建议

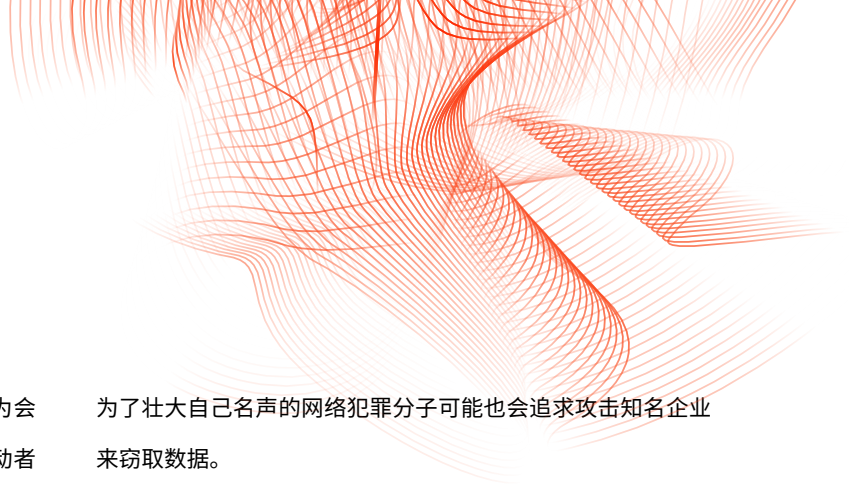
UNIT 42 执行建议：

通过扩展检测和响应 (XDR) 技术确保全面的可视性

在保护您的企业免受威胁时，您必须能够看到这些威胁。保护企业的最佳方法之一是提高环境中活动的可视性。Cortex XDR 技术允许防御者近乎实时地查看端点上的活动并快速响应攻击。

通过授权您的防御者在检测到恶意活动时隔离计算机，您可以帮助降低攻击者传播到其他端点的可能性。这反过来会减少勒索软件加密的影响。为了加强保护，成熟的企业会通过安全编排、自动化和响应 (Cortex XSOAR) 技术自动执行此隔离。这一点很重要，因为攻击者可能会在团队不工作时发动攻击。

阅读 使用 MITRE ATT&CK 缓解网络风险，了解 Unit 42 事件响应者的一组深入建议。



谁正在受到攻击？

对勒索感兴趣的威胁行动者通常是机会主义者，以他们认为会支付的任何企业为目标。由于一些犯罪分子为其他威胁行动者提供服务，因此很难辨别特定团伙的行为。部分原因在于，勒索会影响各个行业和地区的大大小小的企业。

然而，许多团伙都专注于可盈利企业，这种做法有时被称为“大猎杀”。大型跨国企业通常有能力支付更大数额的金钱，并且有着避免业务运营中断这一支付动机。尽管这些企业可能已做好更充分的准备来抵御日常网络攻击，但它们仍然容易受到勒索。

例如，保护程度较低的子公司、卫星办公室或远程工作人员可能会受到勒索软件的影响，勒索软件会试图横向移动以访问企业的重要资产。我们观察到勒索软件团伙将精力集中在区域办公室，这种做法可能会影响更大的企业。

为了壮大自己名声的网络犯罪分子可能也会追求攻击知名企业来窃取数据。

在部分案例中，威胁行动者会表现出政治动机或地区偏好。例如，已观察到一些勒索软件样本会检查系统中的典型东欧语言西里尔字符，并在发现文件时避免加密文件。

有时，勒索者似乎确实偏爱特定行业的目标。例如，Vice Society 以针对教育机构而闻名。

结合我们对事件响应案例的观察和我们对暗网泄密网站活动的持续监控，我们可以了解犯罪团伙正在攻击哪个目标。

来自暗网泄密网站的见解

每天，我们的威胁研究人员都会看到大约 7 个新受害者的信息被发布到暗网泄密网站，平均每 4 小时大约有一个公开发布的新勒索目标。2022 年，泄密网站上发布了 2,679 名受害者的姓名和危害证明，比 2021 年观察到的数字高出约 4%。

2022 年，勒索团伙 LockBit 在其泄密网站上发布了有关 801 家被攻击企业的信息，这是我们在过去两年中从任何一个团伙中观察到的最高受害者数量。LockBit 在 2021 年发布了 409 家受害者，这意味着与去年相比，2022 年受害者数量增加了 95%。相比之下，Conti 在 2021 年公布了 511 家受害者。

对世界上最大企业的攻击只占这些事件的一小部分，但仍然值得注意。2022 年，福布斯全球 2000 强榜单上的 30 家企业公开受到 LockBit、Conti、BlackCat、Hive 和 Black Basta 等团伙勒索企图的影响。自 2019 年以来，这些企业中至少有 96 家的机密文件在某种程度上被公开暴露，这是勒索尝试的一部分。

另外值得一提的是，当我们追踪其信息发布在泄密网站上的企业时，我们通常会关注那些选择不按犯罪团伙最初要求支付赎金的企业。因此，维护泄密网站的团伙在全球的实际影响比我们观察到的要高，据推测，一些企业选择付费以防止他们的信息进入暗网。

2022 年，Conti 和 REvil 等少数频繁实施多重勒索策略的团伙解散了。但是，我们预期其他犯罪分子会继续大量使用这种勒索方法。如上所述，在 2022 年底涉及谈判的勒索软件案件中，有大约 70% 网络犯罪分子威胁要泄露被盗数据。网络安全行业还观察到一些迹象，表明来自 Conti 和 REvil 团伙的个人继续对网络犯罪社区产生影响，因为这些团伙的前成员开始了新的非法活动，并保留着许多战术。

虽然这些迹象是勒索者对企业造成损害的证据，但泄密网站还提供了对这些团伙的资源、能力和典型方法的可视性。作为我们对全球威胁态势持续监控的一部分，Unit 42 会密切关注这些团伙。

数据勒索团伙和全球 2000 强企业

Karakurt 被命名为“Conti 的勒索分支”，是 2022 年的各种臭名昭著的事件始作俑者。例如，他们攻击了中国最大的投资控股公司之一，据称窃取了 320 GB 的公司数据。

该团伙通过他们自己的专业知识或通过支付初始访问代理（这些代理出售对被入侵网络的访问权限）来获得对公司网络的访问权限。Karakurt 放弃加密，转而采用其他勒索方法，例如通过骚扰电子邮件和电话联系受害的员工、业务合作伙伴和客户，以迫使受害者接受合作。他们经常使用企业自己的数据来对抗企业，从而使情况恶化。

其他团伙试图通过攻击世界上最知名的企业来壮大自己的名声。例如，2021 年年中出现的网络犯罪团伙 Lapsus\$ 入侵了 NVIDIA、三星、微软和 LG 等企业。

为实现这一目标，Lapsus\$ 主要使用社交工程（包括网络钓鱼和 SIM 交换）进行初始访问。该团伙还试图诱使心怀不满的员工向他们提供内部信息以换取报酬。即使是防御严密的企业也很难防止这种针对内部人员的攻击。

虽然该团伙勒索了一些受害者，但他们有时似乎对入侵知名目标，从而壮大自己的名声更感兴趣。

建议

UNIT 42 执行建议：

实施威胁情报计划

企业可以了解威胁行动者用来成功入侵同行并进行攻击的战术、技术和程序 (TTP)。企业必须具有资金和人员齐备的特许威胁情报计划。

该计划将为蓝队及他们的捍卫者提供来自威胁情报团队的全新、具体的指标。这些指标可用于监控最新的 TTP，从而能够快速检测和缓解全面的勒索软件攻击。

Unit 42 顾问可以根据从我们的事件响应调查中吸取的经验教训，帮助设计知晓威胁的现代化安全计划，或提高现有计划的有效性。

阅读[使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。

受影响最严重的行业

根据 Unit 42 的数据和暗网泄密网站数据，制造业是 2022 年受勒索攻击影响最大的行业之一，各网站列出了 447 家受害者。紧随其后的是专业和法律服务行业，有 343 家受害者。

企业经常在使用过时软件的系统上运行的行业可能会受到更大的影响。当企业难以定期更新或打补丁时，威胁行动者就可能会利用旧漏洞发起攻击。

这为威胁行动者提供了一个快速扩大的攻击面，他们可以通过该攻击面部署攻击。规模越大，支出越大。

犯罪分子通常在对业务运营及时提供某些产品或服务来说至关重要的行业中寻找目标。这些团伙的目标是利用这些企业在按时完成交付和产生交付成果方面所面临的压力，寄希望于这种压力能够使他们迅速全额支付赎金。运营停机造成的收入损失也会迫使企业屈服于威胁行为者的要求。

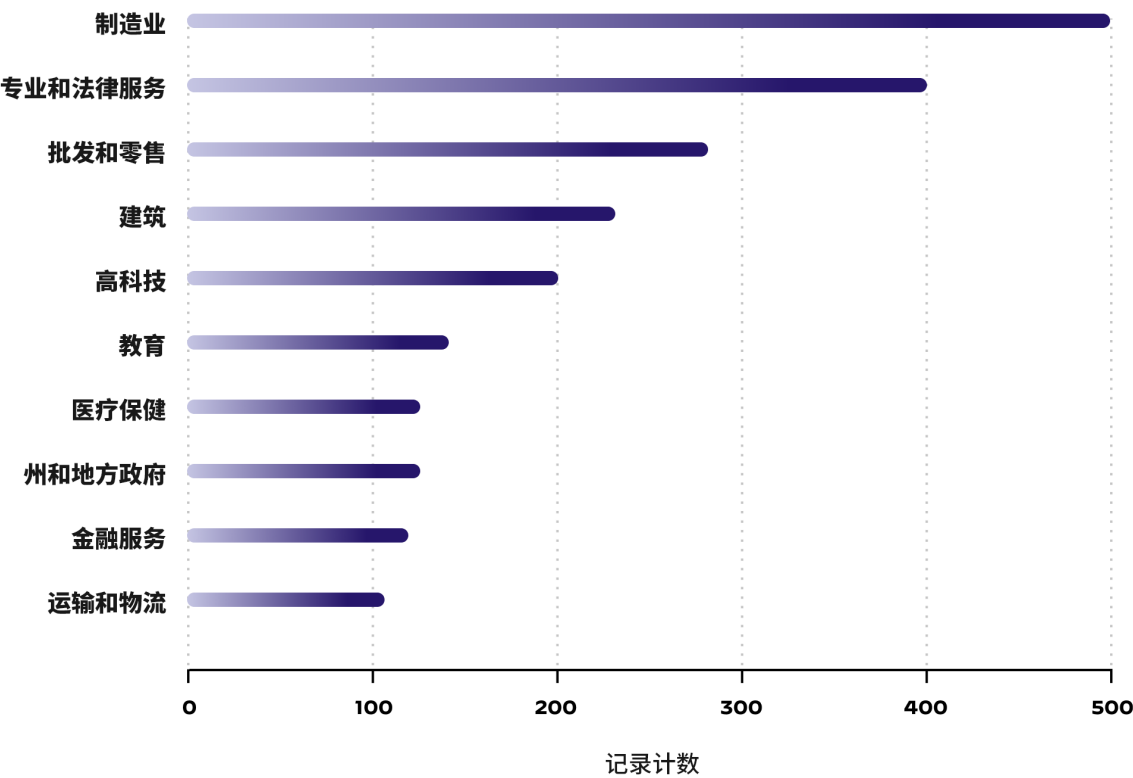


图 4. 受勒索攻击影响最严重的行业（泄密网站数据，2022 年）

建议

UNIT 42 执行建议：

主动管理和减少您的攻击面清单

Unit 42 的事件响应团队发现的数量惊人（至少 75%）的勒索软件攻击和违规行为的始作俑者相同，那就是攻击面暴露。企业必须持续监控其外部攻击面的健康状况、清单和准确性。

当我们的客户在其环境中使用我们的主动攻击面管理（ASM）解决方案 Cortex Xpanse 时，Xpanse 会持续监控所有联网资产并发现未知风险。一旦我们收到来自 Xpanse 的情境化结果，我们就可以对结果进行优先排序，以使安全问题与企业的关键资产保持一致。

为了说明这一点，Xpanse 的分析报告显示了所有运行远程桌面协议 (RDP) 且可直接从互联网访问的系统。然后，客户可以决定 Xpanse 是否应该自动修复这些风险。RDP 是威胁行动者用于初始访问的最常见功能。此外，一旦攻击者在目标网络中站稳脚跟，RDP 就是最有效的横向移动工具。

我们还经常看到网络犯罪分子利用过期的证书、弃用的服务器操作系统版本和报废的电子邮件平台，这些现象都是 Xpanse 自动发现的。这些现象都直接暴露在互联网上，为威胁行动者提供了一条阻力最小的途径。

如果您的企业没有准确的外部攻击面盘点（包括您的云资产），或者没有主动监控外部资产的变化，强烈建议您[执行攻击面评估](#)。

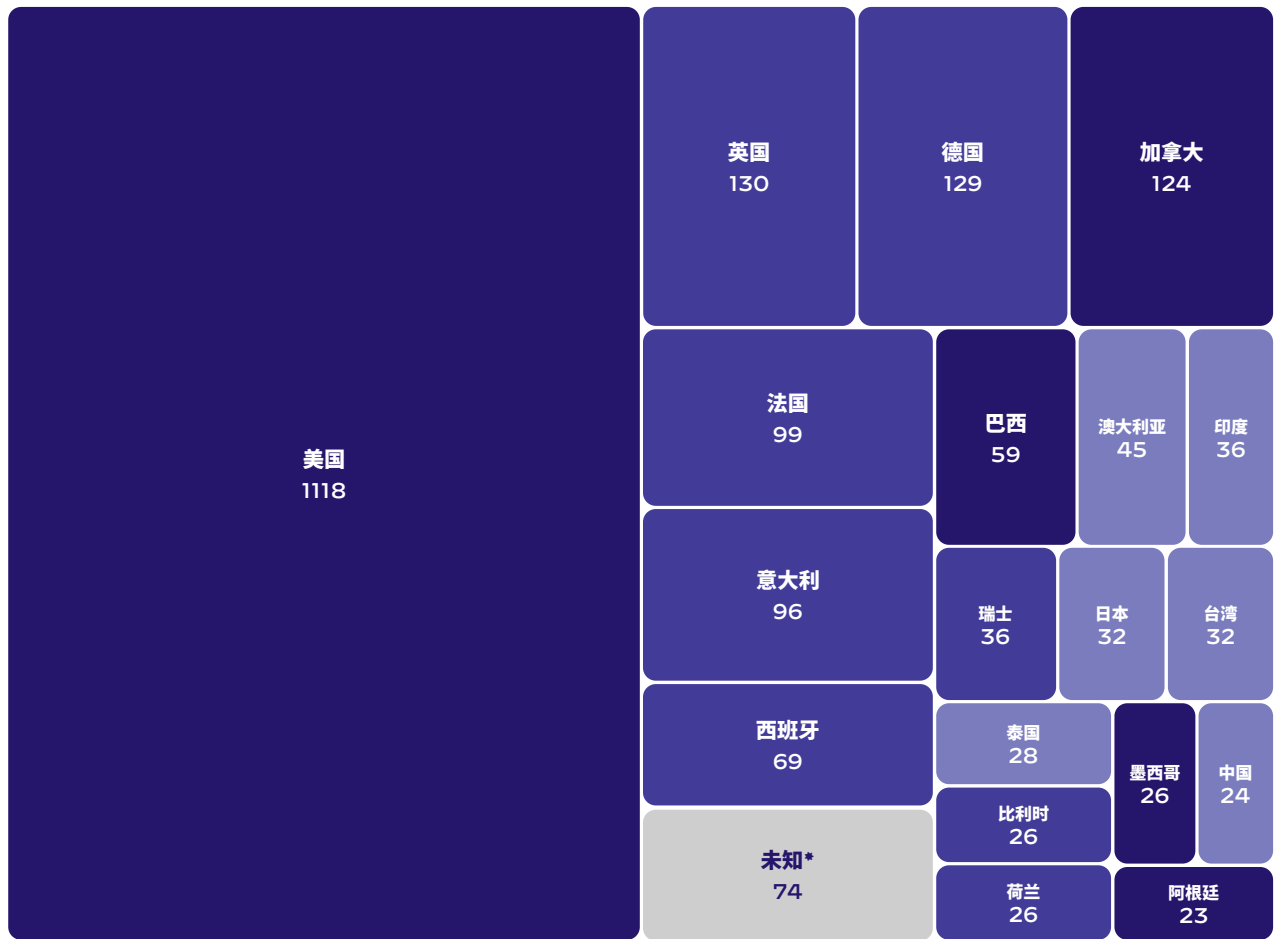
阅读[使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。

受影响最严重的地区

泄密网站数据表明，●美洲地区在 2022 年受到勒索企图的打击最严重，其次是●欧洲、中东和非洲 (EMEA)，以及●亚太地区 (JAPAC)。

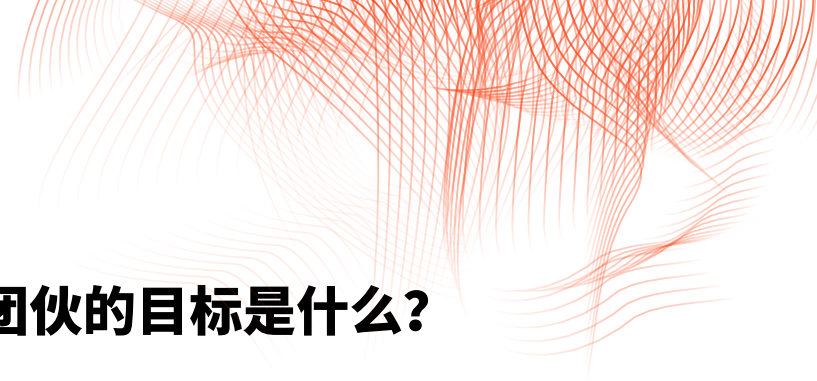
在按国家/地区查看泄密网站上发布的企业时，美国仍然是受影响最严重的国家，占 2022 年观察到的泄密事件的 42%。其次是德国和英国，各占近 5%。

出于金钱目标，威胁行动者通常关注位于美国的盈利企业。然而，尽管攻击集中在美国，但犯罪团伙在全球范围内都有存在，并且在 2022 年观察到影响 107 个国家/地区的企业。



*我们的数据包括 74 个无法识别国家/地区的案例。

图 5. 受勒索企图影响的主要国家/地区（2022 年泄密网站数据）



勒索威胁团伙的目标是什么？

虽然显而易见的答案是“金钱”，但从网络犯罪分子的角度审视一下您的企业中哪些因素会转化为经济利益可能会有所帮助。

首先，威胁行动者希望对您施压。您的压力越大，支付赎金的可能性就越大。当网络犯罪分子在加密之外使用骚扰和催促等战术时，他们试图让您感到失控和压力，让您按照他们的意愿行事。

威胁行动者加强施压的另一种方式是在您的系统中搜索有关任何保单或金融资产的信息。我们的事件响应人员遇到过威胁行动者，他们在谈判期间引用这些内部资源并使用这些信息，来形成关于企业可以支付多高赎金的意向。

然而，今天的威胁行动者也在寻找提高收入的方法。这意味着他们不仅在寻找停止目标企业业务运营的方法，而且还在寻找可能对第三方有价值的信息。

这为威胁行动者创造了双赢局面。如果目标企业选择支付所要求的费用，威胁行动者就会获利。如果企业选择不付款，威胁行动者仍然可以通过出售泄露信息来获利。在一些案例中，网络犯罪分子甚至可以尝试双管齐下，同时利用这两种方式获取收入。

我们经常看到威胁行动者在系统中搜索身份证号、密码和其他凭据等个人信息。威胁行动者可能以护照和税表为目标。

威胁行动者知道许多企业在法律上（和道德上）有义务保护此类信息。跨国企业受世界各地网络法规和数据保护法的约束，不满足这些要求可能会导致罚款、制裁、吊销营业执照，甚至被监禁。威胁行动者可以利用这些类型的后果对其目标施加影响。

可用于身份窃取的信息通常可能会出售给其他犯罪分子。当威胁行动者搜索密码时，他们可能希望将对受感染网络的初始访问权出售给其他犯罪分子，或者他们可能正在寻找进一步破坏并深入企业系统的方法。

这些活动强调了除备份之外保护您的系统的必要性。了解哪些信息对您的企业最敏感和最有价值，并了解这些信息的存储方式以及可访问这些信息的用户，这一点至关重要。零信任方法有助于最大限度地减少威胁行动者在首次入侵后可能造成的损害。

建议

UNIT 42 执行建议：

实施企业范围的零信任架构

有能力快速控制攻击面范围的企业将减少威胁行动者在成功规避其他控制措施时所产生的影响。设置有效的零信任架构可以降低威胁行动者进行横向移动的风险，这是许多类型攻击之前的一个关键指标。

战胜网络攻击的很大一部分，是指让攻击者的攻击难以得逞。虽然实施零信任网络架构（或 ZTNA）不能一蹴而就，但可以将其作为更有效的框架之一，特别是 ZTNA 2.0，它是 ZTNA 的改进版本。该框架有助于创建安全层，从而减慢并防止攻击者成功地在网络中横向移动。

此框架有助于强迫攻击者产生更多干扰，以便其在控制范围内四处移动或穿行，同时也可以减慢其速度。这两种方式都可以为检测和响应提供更多时间，让您有更好的机会正确遏制和补救威胁。

更进一步，您可以使用 Prisma SASE 实施 安全访问服务边缘 (SASE) 框架。Prisma SASE 建立在 ZTNA 的原则之上，但除了其他原则外，还增加了关于跨网络流量和云平台的额外控制层的指导。

阅读 [使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。

从攻击中可以知道哪些信息： 示例勒索软件事件

攻击不是单个恶意操作。破坏您的网络只是相当复杂的过程的一个步骤。好消息是，每当威胁行动者在您的网络中采取行动以进一步实现其犯罪目标时，您就有机会检测他们的存在或防止他们产生影响。

下面，我们讲述一个示例勒索软件事件，该事件已映射到 MITRE ATT&CK 战略和技术。这提供了一个示例，说明勒索团伙如何追求最大利益。在规划您的企业的防御时，评估您如何响应使用这些 TTP 的威胁行动者可能是一个有用的练习。

勒索软件的财务影响

2022 年，Unit 42 观察到了：

- 赎金索要最低 3,000 美元，最高 5000 万美元。
- 赎金支付最低 3,000 美元，最高 700 万美元。
- 赎金索要中位数为 650,000 美元，而赎金支付的中位数为 350,000 美元，比最初的赎金索要中位数下降了 46%。

建议

UNIT 42 执行建议：

对您的 IR 计划和程序进行压力测试

持续审查、更新和测试其事件响应计划的企业更有可能有效响应并遏制主动攻击。企业执行沙盘推演、紫队演习和违规模拟（自动和手动），并与 Unit 42 顾问合作，在响应主动攻击时更能加强自己的速度和准备。

这些演习建立了内部和外部的沟通节奏，建立了利益相关者关系，并在攻击发生之前促进了环境知识共享。这显著增加了早期支持和遏制的可能性。此外，这些演习可能会发现机会或差距，一旦差距缩小，就会改善事件响应态势。

阅读[使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。

从首次活动到最终影响： MITRE ATT&CK 流程图

注意：下面叙述中的某些操作与多种战术和技术相关，但为了简洁起见，每一行只列出了一种。





命令和控制 | T1219: 远程访问软件

威胁行动者下载 ATERA 远程监视和管理 (RMM) 工具，并将其安装到员工的计算机上。



泄露 | T1048: 通过备选协议泄露

威胁行动者使用 rclone 工具将文件从受害企业的文件服务器复制到远程文件传输协议 (FTP) 服务器。



防御规避 | T1562.001: 削弱防御: 禁用或修改工具

威胁行动者通过 Splashtop (已安装) 远程连接到服务器，并执行了一个命令，以禁用 Windows Defender 防病毒解决方案的功能：

"Set-MpPreference -DisableRealtimeMonitoring \$true"



影响 | T1490: 妨碍系统恢复

威胁行动者使用了一个批处理脚本，还停止了各种服务并删除了所有卷影副本，以提高其勒索软件的有效性并抑制系统恢复工作。



横向扩散 | T1570: 横向工具转移

威胁行动者将勒索软件和上述批处理脚本部署到受害企业网络中的数百个系统。



执行 | T1569.002: 系统服务: 服务执行

威胁行动者使用 PsExec 在数百个系统上执行上述批处理脚本和勒索软件可执行文件。



影响 | T1486: 加密数据以造成影响

勒索软件在受害企业网络中的数百个系统上加密文件，包括可以从受感染系统访问的共享文件夹和驱动器中。勒索软件在受影响的位置创建了勒索信副本，并在受害者网络环境中的联网打印机上实际打印了勒索信。

太大了 - 这里什么都看不见!

Unit 42 继续看到威胁行动者人为地增加恶意脚本和实用程序的大小以逃避自动扫描工具，这些工具通常出于性能原因具有文件大小限制（T1027.001：文件或信息混淆：二进制填充）。通过向恶意实用程序添加“垃圾数据”，这些恶意文件可能会逃避某些防病毒和其他安全软件解决方案的检测，具体取决于它们的配置。

APT 何时使用勒索软件

拥有成熟安全程序的大型企业的安全负责人有时会为勒索软件事件分配较低的风险级别。这些企业通常拥有足够的安全工具、强大的网络责任保险和强大的数据恢复程序或操作冗余。这些企业通常更关心抵御民族国家攻击者和高级持续性威胁 (APT) 的团伙，而不是勒索软件。

虽然关注坚定和高技能的威胁团伙是有意义的，这些威胁行动者甚至可以规避成熟企业的安全控制，但消除勒索软件的威胁可能会忽视 APT 团伙现在运作的罕见但影响很大的勒索软件攻击。

一些 APT 团伙使用勒索软件为个人或企业筹集资金。在其他案例中，威胁行动者使用勒索软件来分散对更大、更有影响力的入侵的注意力。

APT 金钱动机

来自观察到在攻击中使用勒索软件的国家（包括朝鲜和伊朗）的威胁团伙也属于目前受到美国政府经济禁运或制裁的团伙。这可能会给他们额外的动力来寻求经济利益，并带来法律后果，可能使企业无法按要求支付赎金。

来自朝鲜的威胁团伙似乎对经济利益特别感兴趣，因为在他们的攻击中观察到的其他战术（例如加密货币盗窃和 ATM 提现）也符合这种模式。

勒索软件支付（在某些情况下）可以帮助资助这些国家的国内计划，这导致美国网络安全基础设施和安全局 (CISA) 警告称，支付勒索软件运营者可能会带来制裁风险。他们还指出，当企业采取积极措施防止勒索软件攻击时，美国财政部外国资产控制办公室 (OFAC) 更有可能通过非公开执法回应来解决明显的制裁违规行为。

英国金融制裁实施办公室 (OFSI) 在 2 月份对一些与勒索软件团伙有关的个人实施了制裁。OFSI 的指导表明其目的是“破坏和降低勒索软件的盈利能力。”

支付赎金可能会受到世界各国政府更严格的审查，尤其是在各国继续制裁俄罗斯的情况下，俄罗斯与许多知名的勒索软件团伙有关联。

APT Smoke Screens 和 Red Herrings

其他威胁团伙，包括伊朗或中国的一些团伙，在使用勒索软件时似乎有不同的目标。威胁行动者可以从部署勒索软件中获得的不仅仅是金钱，同时还具有破坏和间谍活动的潜力。

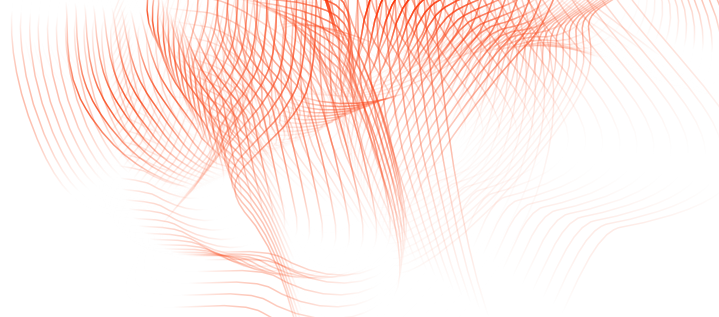
一些恶意软件作者已采取措施模糊勒索软件和擦除器之间的界限。伊朗攻击者专门使用擦除器来达到破坏效果。擦除器对于消除威胁团伙活动证据非常有用，同时还能制造勒索软件攻击的假象。如果这种方法成功，企业可能不会意识到威胁团伙入侵的真正目的。

同样，勒索软件已被用作一种将知识产权盗窃或网络间谍活动伪装得更平庸的方式。APT 团伙从环境中窃取数据，并试图将其作为多重勒索方案进行传递，并承诺在支付赎金后销毁数据。实际上，被盗数据没有被销毁，很可能被威胁者利用。

抵御 APT 和网络犯罪团伙

用于为 APT 或网络犯罪团伙部署勒索软件的 TTP 通常是相同的。这两种团伙都利用漏洞来访问目标系统，然后破坏凭据并横向移动。

对于这些公共区域，企业必须关注其防御和可视性。遗憾的是，支付赎金并不总是故事的结局。在我们看到的大多数案例中，APT 团伙和勒索软件团伙使用多重勒索，这是一种明显的勒索软件攻击，通常与数据泄露有关。由于网络保险提供商声称不承保战争行为，因此这一点尤其令人担忧。在某些案例中，可以这样定义可归因于 APT 攻击者的勒索软件攻击。



结语

2023 年勒索团伙将如何发展

关于威胁形势，最重要的信息不在过去，而在未来。当我们询问事件响应人员和威胁情报分析师以了解勒索行为时，他们给出了一些关键预测。

预测 #1：政府的参与将是破坏勒索团伙运作的关键。

禁止向某些团体和国家/地区付款已经改变了勒索软件和勒索业务的格局。在某些案例中，对制裁的担忧可能会影响更多企业，导致他们拒绝向威胁团伙付款，从而降低收入并导致联盟放弃已知团体，转而与未经制裁的团体合作。

预测 #2：今年将出现大型云勒索软件攻击。

迄今为止，我们的大多数云事件响应案例都表明赎金对威胁行动者来说触手可及。企业经常忽视基本的安全控制，没有做到利用主要云服务提供商提供的安全功能或其他增强的云安全工具。虽然威胁行动者知道这些差距，但他们大多选择不利用这些安全问题进行勒索，因为他们需要解决云环境中的一些复杂问题。

然而，我们始终清楚，勒索软件攻击者会转而关注云环境，并参与需要更多技能的攻击，这些攻击由于对企业有潜在的运营影响，因此回报更大。近年来，Unit 42 追踪了云威胁行动者，也就是通过对云平台资源、服务或嵌入式元数据的直接和持续访问对企业构成威胁的个人或团体。这些威胁行动者已经发展了他们的 TTP，专门针对云工作负载。

虽然责任共担模式减轻了用户在保护云中基础架构、平台和软件方面的负担，但我们看到企业（尤其世界最大的企业）将越来越多的有价值数据和工作负载转移到公有云。2023 年，这将诱使威胁行动者做出在云环境中部署勒索软件所需的调整。

发生这种情况时，将引发有关责任共担模式的新问题，尤其是如果部署在云服务提供商平台上的勒索软件设法影响多个客户端。

建议

UNIT 42 执行建议：

保护云架构

威胁行动者将继续武装自己，并构建攻击有效负载以破坏云工作负载。因此，全面的云安全计划（从治理的角度来看）和云安全平台（从技术控制的角度来看）的部署对于企业来说是不可或缺的。云安全平台应该能够检测和防止对云工作负载、网络安全、代码（包括基础架构即代码和源代码）、容器、身份和密钥以及数据的攻击。

Prisma Cloud 是提供全面云原生安全性的平台范例之一。

阅读[使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。

预测 #3：威胁行为者将找到新的初始访问方式。

我们的事件响应人员发现威胁行为者转向不同的初始访问方法，包括 SEO 中毒（尤其是通过恶意广告增强）、回叫网络钓鱼以及虚假软件安装和/或更新。这是因为引入社交工程元素的有效性，以及远离其他通常检测到的方法的需要。

预测 #4：威胁行动者将增加额外的勒索方法。

我们的数据显示与加密相关的数据窃取和骚扰有所增加。我们预计这种趋势会持续下去，因为威胁行动者会通过增加支付压力来提高较低的成功率。这引出了我们的下一个预测。

预测 #5：没有加密的勒索将会增加。

由于威胁行动者通过向勒索软件添加勒索方法取得了成功，因此部分团伙得出结论，认为勒索本身可能是有效的。放弃加密步骤允许威胁行动者降低攻击技术的复杂性。我们预期会有更多的团伙探索这种方法。

什么是 SEO 中毒？

威胁行动者利用搜索引擎优化 (SEO) 感染潜在受害者。Unit 42 经常看到这种形式的（虚假）软件下载、浏览器更新或恶意文档模板。例如，威胁行动者会破坏合法网站并共享常见业务文档类型的假定模板，例如某些会计核算或人力资源表格，而这些文件包含恶意软件。当受害者搜索某种模板（例如发票模板）时，他们会通过搜索结果找到恶意文件，并在下载并打开后感染恶意软件。这种恶意软件为威胁行动者提供了进入受害者环境的立足点。Unit 42 多次看到与此技术相关的 GootLoader 和 SocGholish。

预测 #6：以政治目的为动机的勒索软件事件数量将会上升。

勒索软件和勒索行为最明显的目的是为了经济利益。但是，在某些情况下，这些活动可能与政治动机有关。团伙可能会使用勒索软件来资助其他出于政治动机的活动。他们还可能使用勒索软件和勒索行为来扰乱政治流程，破坏关键基础架构的稳定性，对政府造成恐惧和愤怒，并挑拨离间。

预测 #7：内部威胁将导致勒索企图。

仅在 2023 年，就有 300 多家科技公司裁员超过 10 万人。一些受影响的人会怀恨在心，并且有能力报复。内部威胁可能特别危险，因为员工更有可能知晓宝贵资产的保存位置。在当今的环境中，内部威胁可以通过向网络犯罪团伙出售访问权限和其他信息来掩盖他们的身份，从而使该行为可能更具诱惑力。

预测 #8：攻击者会先感染受害者的供应链和源代码，然后再使用勒索软件分散供应链感染的注意力。

随着越来越多的企业了解如何处理勒索软件，他们可能会开始将勒索软件感染视为常态。威胁行动者将通过部署勒索软件，利用这一点来分散他们攻击的真正目的。在极端情况下，这可能会让威胁行动者低调行事，同时策划可能影响全球大量企业的攻击。

企业应审查针对勒索软件和勒索行为的事件响应计划，着眼于未来形势。我们预计，积极性很高的威胁行动者将继续加大影响力，以从目标中获得他们想要的东西。我们预计其他类型的威胁团伙会利用已知的网络犯罪技术。负责任的安全领导者应该考虑到，处理当今的勒索技术不仅仅是保护数据（虽然这也很重要）。保护企业的声誉以及员工、合作伙伴和客户的安全也是一项重要责任。

建议

UNIT 42 执行建议：

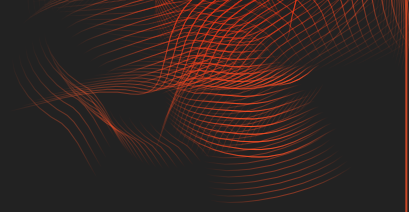
与您的董事会讨论勒索软件和勒索行为

谈到勒索软件，董事会最关心的是风险管理以及企业如何有效地遏制勒索软件对业务的威胁。在新闻中看到同行受到勒索软件或勒索行为的严重打击后，董事会经常会问：“我们能阻止这种类型的攻击吗？”

当CISO被问及此类问题时，他们需要有可靠、客观的数据来回应，这些数据直接反映了董事会最关心的风险。此类风险往往与以下类别相关：

- 战略风险
- 声誉风险
- 合规性和监管问题
- 运营问题
- 财务风险

CISO 的响应应该能够将他们的勒索软件和勒索行为准备能力和预防能力与那些将减轻董事会关注的风险领域的能力联系起来。



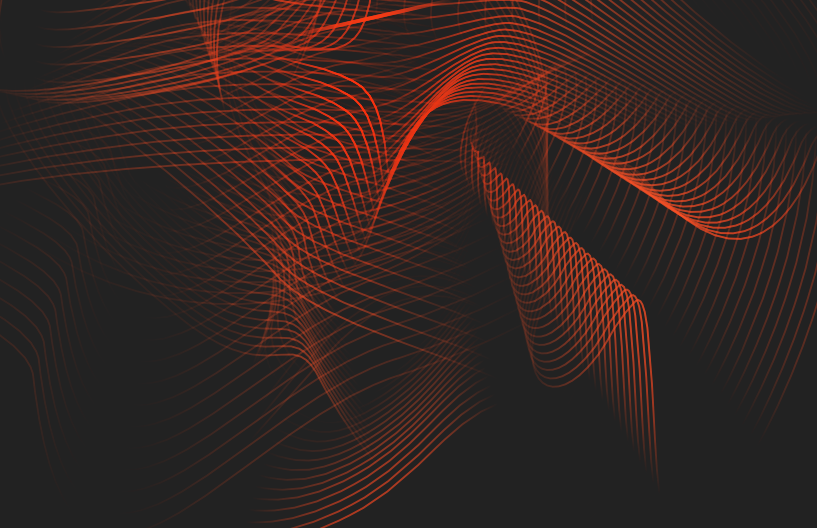
准备好参与这些讨论的企业将重点放在针对已知攻击者战术和技术，主动改进其安全态势。Unit 42 的顾问将应对数千次攻击的经验运用到发现客户弱点的服务中。我们的顾问与客户合作制定路线图并主动弥补差距。

这些值得信赖的安全顾问使用 Palo Alto Networks 技术来完成

- [攻击面评估](#)
- [勒索软件准备情况评估](#)
- [事件响应剧本设计和审核](#)
- [事件模拟演习](#)
- [SOC 转型](#)

Unit 42 顾问还与客户合作，以发现和提高他们的能力，借助与 CISO 的目标和董事会的需求相一致的一系列准备和测试产品做出响应。

阅读[使用 MITRE ATT&CK 缓解网络风险](#)，了解 Unit 42 事件响应者的一组深入建议。



向专家咨询

是否需要勒索软件或勒索事件方面的帮助？请呼叫专家。

如果您的文件和应用不可访问，而原因是勒索软件攻击，请联系我们。[Unit 42 事件响应](#)团队全天候在线，可以迅速帮助调查、遏制和消除威胁，以便您快速恢复运营。我们可以代表您就赎金问题进行谈判，但我们希望您永远都不会用到这项服务。

此外，有关 [Unit 42 顾问人员](#)，您可以通过快速拨号让我们的事件响应专家成为您团队的延伸。您还可以选择将您的咨询积分分配给主动的 Unit 42 网络风险管理服务，例如[勒索软件准备情况评估](#)。

研究方法

在创作此报告时，我们审查了 Unit 42 在 2021 年 5 月至 2022 年 10 月期间完成的一系列大约 1,000 个事件响应案例的结果。我们审查了一小部分案例（大约 100 个案例），深入了解了勒索软件和勒索行为谈判。虽然大多数案例发生在美国，但进行攻击的威胁行动者遍布全球，同时针对全球的企业、组织和 IT 基础设施。

我们还通过对暗网泄密网站的持续监控以及我们的威胁情报分析师跟踪网络犯罪组织和 APT 的工作中收集了信息。

最后，我们通过与经验丰富的安全顾问进行深入访谈来补充我们的案例数据，以根据他们在特定专业领域与合作客户的合作收集建议和预测。

Unit 42 事件响应方法

攻击未得到解决的每一分钟都会让您的企业损失钱财，并可能损害声誉。有了 Unit 42 事件响应小组的专家在您身边，您可以迅速开始调查，并利用我们应对数千起与您类似的事件的经验。凭借我们针对事件响应的基于威胁的方法和跨端点、网络和高云的高级工具，我们提供快速遏制，以最大限度地减少对您的业务的影响。

Unit 42 的平均响应时间（我们在收到求助请求后进行初步联系所需的时间）远低于 15 分钟。一旦接到电话，我们会迅速了解入侵的全部范围、受影响的系统以及已经采取的安全措施，以便我们能够快速控制事件。我们可以快速地远程执行此操作，以帮助您的快速响应事件。我们遵循下述经过证明的方法。

我们遵循经过证明的方法：

范围

为了准确了解事件，正确的范围界定阶段至关重要。这使我们能够调整正确的资源和技能组合，使您的企业尽快恢复运行，并准确估计为您提供帮助所需的工作量。

调查

我们会在调查事件时全力了解事件，利用可用数据并与团队通力合作。

保护

随着事件得到控制，威胁行动者及其工具从您的环境中被根除，我们同时协助您的企业快速恢复运营。

支持和报告

Unit 42 还将帮助您了解事件的根本原因和潜在影响，包括任何未经授权的访问或获取可能引发法律义务的敏感信息。

转型

我们认为，事件响应的一个关键步骤是帮助确保未来安全态势得到改善。我们与您合作应用特定的改进并制定事件响应计划，从而提供保护，防止未来和类似的攻击。

详细了解 Unit 42 事件响应服务



范围

定义参与范围

评估安全事件的广度、严重程度和性质。



调查

全面了解事件

我们的专家使用先进的证据收集、检测和分析工具来标记 IoC、TTP 和其他线索。



保护

控制并根除

我们通过自定义根除策略消除威胁，并针对新的恶意活动提供全天候监控。



支持和报告

调查结果和响应援助

获取详细的调查报告，以及在重新振作起来时实施额外安全控制的指导。



转型

改善安全态势

利用学到的经验教训对您的安全方法进行具体改进，以防范未来和类似的攻击。



关于 Palo Alto Networks

Palo Alto Networks 是世界网络安全领导者。我们通过创新来打击网络威胁，因此企业可以满怀信心地采用我们的技术。我们为全球各行各业成千上万个客户提供新一代网络安全。我们一流的网络安全平台和服务以行业领先的威胁情报为后盾，并通过最先进的自动化技术得到增强。无论是部署我们的产品以实现零信任企业、响应安全事件，还是通过与世界级合作伙伴生态系统合作提升安全成果，我们都致力于确保每一天的安全性更上一层楼。基于这一点，我们成为了首选的网络安全合作伙伴。

Palo Alto Networks 致力于汇聚最优秀的人才来完成我们的使命，因此我们也很自豪能够成为首选网络安全办公平台，并被《新闻周刊》评为最受欢迎的办公平台（2021 年）、最佳多元化公司（2021 年）和致力于 LGBTQ 群体平等的 HRC 最佳职场（2022 年）。有关详细信息，请访问 www.paloaltonetworks.com。

关于 Unit 42

Palo Alto Networks Unit 42 将世界知名的威胁研究人员、优秀的事件响应人员和安全顾问专家聚集在一起，打造出以情报为导向、随时准备响应的企业，致力于帮助您主动管理网络风险。我们的团队将成为值得信赖的顾问，助您评估和测试针对相应威胁的安全控制措施，利用基于威胁的方法转变您的安全策略，并在短时间内响应事件，以便您快速恢复业务。请访问 paloaltonetworks.com/unit42。



免费咨询热线：400 9911 194

网址：www.paloaltonetworks.cn

邮箱：contact_salesAPAC@paloaltonetworks.com



© 2023 Palo Alto Networks, Inc. Palo Alto Networks 是 Palo Alto Networks 的注册商标。如需我们的商标列表，请参阅 www.paloaltonetworks.com/company/trademarks.html。

此文档中提及的所有其他商标可能是各相应公司的商标。2023 年 Unit 42 勒索软件和勒索行为报告 03/2023。